SCOUTQA-TEST · ANÁLISIS QA · METODOLOGÍA GITHUB/AWESOME-COPILOT

Smoke Studio R2
Reporte de Análisis QA

Revisión estática completa · 27 incidencias encontradas · 4 páginas HTML

FECHA	RAMA	ANALISTA
2026-04-22	main · 8085816	Claude Code
SKILL	**STACK**	**TOTAL INCIDENCIAS**
scoutqa-test	HTML5 / CSS3 / JS	27

- 3 Críticos
- 5 Altos
- 8 Medios
- 7 Bajos

Resumen Ejecutivo

Estado general del proyecto por dimensión de calidad

3	5	8	7	4
CRÍTICOS	ALTOS	MEDIOS	BAJOS	ACCESIBILIDAD

Estructura HTML **8/10** ✅	Sistema CSS **8/10** ✅	JS Core (main.js) **7/10** ✅
JS SmokeScan **4/10** ⚠️	Responsivo **8/10** ✅	Rendimiento **3/10** ❌
Accesibilidad **6/10** ⚠️	SEO **5/10** ⚠️	Seguridad **2/10** ❌
Firebase **0/10** ❌	Gemini AI **0/10** ❌	Calidad de Código **5/10** ⚠️

Metodología

scoutqa-test — github/awesome-copilot

→ Smoke Test de funcionalidad crítica

→ Análisis de Seguridad (OWASP Top 10)

→ Revisión de Calidad de Código

→ Auditoría de Accesibilidad WCAG 2.1

→ Evaluación de Rendimiento

→ SEO — meta tags, schema, sitemap

> **Alcance:** Análisis estático completo sobre 4 archivos HTML (4,873 líneas), 2 CSS (4,729 líneas) y 2 JS (1,793 líneas). El análisis live vía `scoutqa CLI` requiere cuenta activa en ScoutQA.ai y URL del sitio en producción.

Incidencias Críticas

Bloqueantes de producción — requieren corrección inmediata

C-01 Firebase no configurado — Autenticación completamente rota

CRÍTICO

ARCHIVO

`smokescan.js · líneas 1135-1141`

IMPACTO

SmokeScan no puede autenticar usuarios ni persistir datos. OAuth Google/Microsoft completamente no funcional.

EVIDENCIA

```
const firebaseConfig = {
  apiKey: "TU_API_KEY",
  authDomain: "tu-proyecto.firebaseapp.com",
  // ...
};
```

RECOMENDACIÓN

Crear proyecto Firebase real, configurar variables de entorno (no hardcodear), activar Google/Microsoft OAuth providers. Nunca commitar credenciales reales.

C-02 API Key de Gemini ausente — Función AI completamente rota

CRÍTICO

ARCHIVO

`smokescan.js · STATE.apiKey`

IMPACTO

La característica core del producto (análisis AI) no funciona. El sistema cae en modo simulado con respuestas hardcodeadas.

RECOMENDACIÓN

Implementar un backend proxy (Firebase Cloud Functions o Vercel Edge Functions) para las llamadas a Gemini. Nunca exponer API keys en el frontend.

C-03 Sin backend — API keys expuestas si se configuran en frontend

CRÍTICO

ARCHIVO

`smokescan.js · fetchGeminiAnalysis()`

IMPACTO

Sin servidor backend, cualquier API key real configurada en el código frontend quedará expuesta públicamente. Riesgo de abuso masivo y costos ilimitados.

RECOMENDACIÓN

Implementar backend serverless como proxy para todas las llamadas externas. Opciones: Firebase Cloud Functions, Vercel Serverless, o Cloudflare Workers.

Incidencias Altas

Problemas de seguridad y rendimiento significativos

A-01 Vulnerabilidad XSS — innerHTML con datos de usuario sin sanitizar

ALTO

ARCHIVO

`smokescan.js · ~línea 1250`

IMPACTO

Permite inyección de HTML/scripts maliciosos si un atacante controla el nombre de usuario. Patrón peligroso que debe eliminarse.

CÓDIGO PROBLEMÁTICO → SOLUCIÓN

```
// ❌ Problemático
cta.innerHTML = 'Hola, ' + firstName;

// ✅ Correcto
cta.textContent = `Hola, ${firstName}`;
```

A-02 Control de intentos únicamente en cliente — Bypass trivial

ALTO

ARCHIVO

`smokescan.js · FirebaseAuthService`

IMPACTO

El límite de 2 intentos/día se resetea al recargar la página. Cualquier usuario puede usar SmokeScan ilimitado veces generando costos no controlados de API.

A-03 Autenticación simulada activa — Mock mode en codebase

ALTO

ARCHIVO

`smokescan.js · FirebaseAuthService`

IMPACTO

Los usuarios ven un modal de login falso. Si se despliega en este estado, el producto no funciona. console.log filtra información de debugging en producción.

A-04 Sin reglas de seguridad en Firestore

ALTO

ARCHIVO

`firestore.rules (ausente)`

IMPACTO

Sin reglas configuradas, Firestore en modo development permite leer/escribir cualquier dato a cualquier usuario. Exposición total de datos en producción.

A-05 Imágenes sin optimizar — Hasta 1.6 MB por imagen **ALTO**

ARCHIVOS

`problem-stats.jpg (1.6MB) · hero-team.jpg (1.1MB) · cta-team.jpg (945KB)`

IMPACTO

En conexiones móviles el LCP supera 4 segundos, penalizando SEO y conversión. Total de assets: 75 MB.

RECOMENDACIÓN

Comprimir a ≤200KB por imagen, generar variantes WebP, implementar srcset con breakpoints en 400/800/1200px, añadir loading="lazy" en imágenes fuera del viewport inicial.

🟡 Incidencias Medias

Problemas de UX, SEO y calidad que degradan la experiencia

ID	DESCRIPCIÓN	ARCHIVO	RECOMENDACIÓN
M-01	**alert() en UI** — 3 instancias de alert() para errores de usuario	`smokescan.js`	Reemplazar con toast/modal del design system
M-02	**`href=""` vacío** en botón CTA principal	`index.html:590`	Cambiar a `href="javascript:void(0)"`
M-03	**Sin Open Graph** — compartir en redes sin preview	Todas las páginas	Añadir og:title, og:description, og:image, og:url
M-04	**Sin robots.txt ni sitemap.xml**	Raíz del proyecto	Crear ambos archivos
M-05	**Sin JSON-LD schema markup** — sin rich snippets en Google	`index.html`	Añadir schema Organization y WebApplication
M-06	**CDN html2pdf sin SRI** — dependencia sin verificación de integridad	`smokescan.html`	Añadir atributos integrity y crossorigin
M-07	**Código comentado** — CLIENT LOGOS incompleto, nav sync comentado	`index.html:482-502`, `main.js:163-178`	Eliminar o mover a issues de GitHub
M-08	**Magic numbers** — 88, 0.18, 251 hardcodeados sin contexto	`main.js`, `smokescan.js`	Extraer a constantes con nombre descriptivo

🔵 Incidencias Bajas

Deuda técnica y mejoras de documentación

ID	DESCRIPCIÓN	RECOMENDACIÓN
B-01	Sin README.md en el repositorio	Crear con descripción, setup y despliegue
B-02	Sin .env.example	Crear plantilla con todas las variables requeridas
B-03	console.log en producción (4+ instancias)	Eliminar o usar flag DEBUG
B-04	Global STATE no encapsulado	Encapsular en módulo ES6 con getters/setters
B-05	Sin persistencia de sesión en SmokeScan	Usar localStorage para serializar STATE
B-06	Links de contacto apuntan a URL incorrecta	Unificar CTAs a index.html#contacto
B-07	Sin CHANGELOG.md	Iniciar con formato Keep a Changelog

♿ Accesibilidad — WCAG 2.1 AA

ACC-01 Diferenciación solo por color en badges de viabilidad

ACCESIBILIDAD

CRITERIO WCAG

1.4.1 — Use of Color (Level A)

IMPACTO

8% de hombres con daltonismo no puede distinguir estados Verde/Rojo en el score.

SOLUCIÓN

```
// Añadir icono + texto al color
"✓ Alta viabilidad"  (verde)
"⚠ En desarrollo"   (rojo)
```

ACC-02 Score no anunciado via ARIA live regions

ACCESIBILIDAD

SOLUCIÓN

```
<div aria-live="polite" aria-atomic="true" class="sr-only" id="score-announcement">
  Viabilidad actualizada: 68 puntos
</div>
```

ACC-03 **Spinner de carga sin anuncio ARIA** ACCESIBILIDAD

SOLUCIÓN

Añadir `role="status"` al contenedor del loading y `aria-live="polite"` para actualizaciones de progreso durante el análisis AI.

ACC-04 **Animaciones scroll-reveal sin respetar prefers-reduced-motion** ACCESIBILIDAD

SOLUCIÓN

```
@media (prefers-reduced-motion: reduce) {
  .reveal {
    opacity: 1;
    transform: none;
    transition: none;
  }
}
```

Cobertura de Análisis por Página

PÁGINA	SMOKE TEST	ACCESIBILIDAD	RENDIMIENTO	SEGURIDAD
index.html	⚠️ href vacío en CTA	✅ Buena	❌ Imágenes grandes	✅ Sin issues
nosotros.html	✅ OK	✅ Buena	❌ Imágenes grandes	✅ Sin issues
servicios.html	⚠️ Links de contacto incorrectos	✅ Buena	❌ Imágenes grandes	✅ Sin issues
smokescan.html	❌ Auth rota · AI rota	⚠️ Parcial	✅ CSS/JS OK	❌ XSS · Mock auth

Hoja de Ruta de Correcciones

Sprint 1 — Bloqueantes de Producción

1–2 semanas

C-01	Configurar Firebase real con variables de entorno
C-02	Implementar backend proxy para Gemini API
C-03	Remover mock auth, implementar OAuth real
A-01	Corregir XSS — innerHTML → textContent
A-04	Definir reglas de seguridad Firestore

Sprint 2 — Calidad y Experiencia

1 semana

A-02	Mover rate limiting al backend (Firestore)
A-05	Optimizar imágenes + WebP + srcset
M-01	Reemplazar alert() con componentes UI
M-02	Corregir href="" vacío en CTA
ACC-01-04	Todas las correcciones de accesibilidad

Sprint 3 — SEO y Documentación

3–4 días

M-03	Añadir Open Graph meta tags
M-04	Crear robots.txt y sitemap.xml
M-05	Añadir JSON-LD schema markup
B-01	Crear README.md
B-02	Crear .env.example

Sprint 4 — Deuda Técnica

1 semana

M-06-08	SRI en CDN, eliminar dead code, magic numbers → constantes
B-03	Eliminar console.log de producción
B-04	Encapsular STATE en módulo ES6
B-05-07	localStorage, links de contacto, CHANGELOG